

 PREMIER[®] POLICY	TITLE: Secure Software Development Lifecycle Policy	
	DATE CREATED: 03/15/2023	VERSION NUMBER: 1
	DATE OF LAST REVIEW:	DEPARTMENT OWNER: DevSecOps

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

1. Purpose

To establish the required components and steps for software development within our organization, ensuring a secure and consistent approach to software creation and modification.

2. Scope

Applies to all software written, designed or modified by Performance Services' employees or contractors with intended use by Premier staff, customers or members.

Exceptions to scope include internally developed scripts, reports or tools meeting the following requirements:

- Inaccessible to the public, Premier customers or members; and not intended to run as a service, daemon or background task on any Premier servers; or
- Specific software items excepted from this Policy through an approved Security Exception Request for a defined interval.

3. Definitions

Authorized Build and Deployment Platform – A platform approved by the Senior ITS leadership to perform builds, releases and deployments of software ensuring consistency, security and traceability throughout the process.

Authorized Source Control System – A source-control management system approved by the Senior ITS leadership.

Open Source Vulnerability Scanning – A process to identify and assess potential security risks in open source components and dependencies used in the software.

Premier Impact Assessment (PIA) – A formal evaluation conducted to determine the potential impact of changes to the protected data received, stored or collected by the software. Request a PIA through ServiceNow using the [Premier Impact Assessment \(PIA\) catalog item](#). For details, see the [Premier Impact Assessment \(PIA\) Policy](#).

Protected Data – Any sensitive or confidential information that requires safeguarding such as personally identifiable information (PII), financial data or health records.

Static Analysis – The process of analyzing source code without executing the program to identify potential issues such as coding errors, security vulnerabilities or code quality concerns.

Secret Scanning – A process that scans for sensitive information such as API keys, passwords or tokens within the source code to prevent unauthorized access.

Security Exception Request – A security exception request made via ServiceNow using the [Security Exception Request catalog item](#).

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

System Security Plan – A formal document outlining the security requirements, controls and processes for a given software system which is reviewed and updated as needed throughout the software development lifecycle.

Threat Modeling – A structured approach to identifying, quantifying and addressing potential security threats in a software system often conducted during the design phase of development.

Test Coverage Reporting – The process of measuring the extent to which a software's test suite covers the various components, functions or branches of the source code providing insight into the thoroughness of testing efforts.

4. Attachments/References

[Premier Impact Assessment \(PIA\) Policy](#)
[Information Security Vulnerability Management Policy](#)

POLICY

Background

1. The software development process consists of multiple phases, each critical to ensuring secure, reliable and efficient software. This Policy addresses each phase of software development to provide a comprehensive approach to security and quality assurance.
2. The phases of software development are:
 - 2.1 Plan (also known as Design)
 - 2.2 Code
 - 2.3 Build
 - 2.4 Test
 - 2.5 Demonstrate
 - 2.6 Release
 - 2.7 Deploy
 - 2.8 Operate
 - 2.9 Monitor

Plan (Design)

3. Developers must review the system security plan. If the project involves the consumption of new data, the introduction of new functionality, or impacts to security functions, the system security plan must be updated accordingly.
4. A PIA must be completed if there is a change in the protected data received, a change in how protected data is stored, a change in how data is used or if new protected data is collected.
5. If the system security plan has been updated or the application security team has requested it, a threat modeling exercise must be conducted.

Code

6. Developers must store source code in an Authorized Source Control System to ensure proper versioning and access control.
7. Open-source vulnerability scanning must be performed on all dependencies to identify and mitigate potential security risks according to the [Information Security Vulnerability Management Policy](#).

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

8. The use of static analysis tools is highly encouraged to proactively identify and address potential coding issues.
9. Secret scanning tools are highly encouraged to detect and prevent unauthorized access to sensitive information.
10. At least one peer must review and approve changes before they are accepted into the main development branch, channel or venue to maintain code quality and security.

Build

11. The build process must be automated and capable of running on a build agent in an authorized environment to ensure consistency and security.
12. The following steps are strongly encouraged to be included in the automated build process:
 - 12.1 Open-source vulnerability scanning of dependencies to identify and address potential security risks. [Required]
 - 12.2 License scan of included dependencies to ensure compliance with software licensing requirements. [Required]
 - 12.3 Static analysis to proactively identify and address potential coding issues. [Encouraged]
 - 12.4 Secret scanning to detect and prevent unauthorized access to sensitive information. [Encouraged]
 - 12.5 Automated test execution to verify software functionality and stability. [Encouraged]
 - 12.6 Test coverage reporting to assess the thoroughness of testing efforts. [Encouraged]

Test

13. Developers must test each security feature and resolve or document any failures to ensure the software meets security requirements.
14. The use of automated testing, including unit, integration and functional test suites, is highly encouraged to maintain software quality and reduce the potential for human error in the testing process.

Demonstrate

15. Developers are highly encouraged to demonstrate updated functionality and security features to stakeholders and team members, ensuring a comprehensive understanding of the implemented changes and promoting transparency throughout the development process.

Release

16. Developers must document any security concerns prior to release to ensure that stakeholders are aware of potential risks and can make informed decisions regarding the deployment of the software.
17. Releases must be performed using an authorized build and deployment platform to maintain consistency, security and traceability throughout the release process.

Deploy

18. Deployments must be performed using an authorized build and deployment platform to ensure consistency, security, and traceability throughout the deployment process.
19. The use of a lower environment to validate the release is highly encouraged, as it helps identify and address potential issues before deploying to production environments.

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

Operate

20. Periodic and recurring open-source vulnerability scanning must be performed on the software in operation to identify and address potential security risks in a timely manner.
21. Identified vulnerabilities must be addressed in accordance with the [Information Security Vulnerability Management Policy](#) and other relevant policies to maintain the security and integrity of the software.
22. Security controls related to the software in operation must be performed periodically and on a recurring basis to ensure ongoing compliance and maintain a strong security posture.

Monitor

23. Monitoring of security functions and system resources is highly encouraged to ensure the ongoing stability and security of the software.
24. It is encouraged to include alerting and an accompanying playbook for support staff as part of the monitoring process, enabling timely response to potential issues and facilitating efficient resolution.

Where to Go with Questions and Concerns

Contact the Senior Director, Development Platform for questions or concerns about this Policy.